

INSTITUTO NACIONAL DE TELECOMUNICAÇÕES – INATEL

Curso de Mestrado

TP546 – Internet das Coisas e Redes Veiculares

ATIVIDADE 3 – TRABALHO DE PESQUISA

**Credenciais padrão em dispositivos IoT:
comprometimento por botnet e ataques distribuídos
de negação de serviço**

Álvaro Lucio Almeida Ribeiro

Matheus Henrique Fonseca Afonso

Professor: Samuel Baraldi Mafra

Este relatório analisa como credenciais universais, fracas ou mantidas no estado de fábrica permitem o comprometimento automatizado de dispositivos IoT e sua utilização em botnets para ataques distribuídos de negação de serviço.

Santa Rita do Sapucaí – MG

2026

Resumo

A Internet das Coisas conecta câmeras, roteadores, gravadores de vídeo, sensores e atuadores que frequentemente operam com pouca supervisão. Este relatório investiga um problema específico: o uso de credenciais universais, previsíveis ou mantidas no estado de fábrica em serviços de administração acessíveis pela rede. O ataque selecionado é o comprometimento automatizado inspirado na botnet Mirai. Nesse encadeamento, o atacante identifica dispositivos com serviço remoto exposto, testa um conjunto reduzido de credenciais conhecidas, instala um agente e passa a controlar os equipamentos para produzir tráfego de negação de serviço distribuída (DDoS). A literatura registra que o Mirai atingiu um pico de aproximadamente 600 mil infecções e afetou serviços relevantes em 2016. Uma demonstração conceitual em laboratório isolado mostra as etapas e os indicadores observáveis sem propagar código malicioso nem gerar tráfego contra terceiros. A análise indica que trocar a senha após a instalação é necessária, porém insuficiente. A mitigação exige credenciais iniciais únicas ou definidas no primeiro uso, desativação de interfaces desnecessárias, restrição de exposição à Internet, atualização autenticada, segmentação de rede, monitoramento e resposta a incidentes. O problema deve ser tratado conjuntamente por fabricantes, integradores e operadores ao longo do ciclo de vida do produto.

Palavras-chave: Internet das Coisas; segurança; credenciais padrão; botnet; Mirai; DDoS.

1 Introdução

Dispositivos de Internet das Coisas (IoT) combinam sensores, processamento, comunicação e, em alguns casos, atuação física. Essa integração amplia a superfície de ataque: uma câmera ou

um roteador comprometido não é apenas um equipamento defeituoso, mas um computador conectado que pode observar a rede, consumir recursos e enviar tráfego a terceiros. Como muitos produtos são instalados em grande escala e administrados raramente, uma falha repetida em todos os exemplares pode ser explorada de forma automatizada.

O problema escolhido neste trabalho é o uso de senhas fracas, adivinháveis, embutidas no firmware ou compartilhadas por vários dispositivos. A classificação IoT Top 10 da OWASP coloca credenciais fracas, previsíveis ou fixas entre os principais riscos do domínio [1]. A exposição de um serviço de administração agrava a falha porque permite tentativas remotas sem acesso físico. A CISA e a NSA também identificam credenciais padrão como uma configuração recorrente em câmeras, impressoras, equipamentos audiovisuais, telefones IP e outros dispositivos IoT [2].

Para mostrar as consequências concretas, adota-se como estudo de caso a botnet Mirai. O Mirai explorava principalmente dispositivos embarcados acessíveis por Telnet e protegidos por um conjunto limitado de combinações conhecidas de usuário e senha. Após o acesso, o equipamento era incorporado a uma infraestrutura de comando e controle e podia participar de ataques DDoS [3]. O episódio evidencia como uma decisão simples de configuração pode produzir impacto muito além da residência ou organização proprietária do dispositivo.

O objetivo é explicar o problema, apresentar o encadeamento de um ataque específico, propor uma demonstração segura e organizar medidas de prevenção, detecção e resposta. O texto não ensina a invadir sistemas reais: o cenário pressupõe equipamentos próprios ou explicitamente autorizados, rede isolada e geração limitada de tráfego. Essa delimitação permite

compreender o mecanismo sem expor terceiros a risco.

2 Método de pesquisa e escopo

O trabalho utiliza pesquisa bibliográfica e análise de caso. A principal fonte empírica é o estudo longitudinal de Antonakakis et al., apresentado no USENIX Security Symposium de 2017. Os autores combinaram diferentes pontos de observação para reconstruir o crescimento, a composição e os ataques do Mirai entre agosto de 2016 e fevereiro de 2017 [3]. O artigo de Kolias et al. complementa a caracterização das botnets IoT e de seu uso em DDoS [4].

As medidas de mitigação são relacionadas a três referências. O NISTIR 8259A define uma linha de base de capacidades de segurança para dispositivos IoT, incluindo identificação, configuração, proteção de dados, controle de acesso às interfaces, atualização de software e consciência do estado de segurança [5]. A norma ETSI EN 303 645 estabelece requisitos básicos para produtos IoT de consumo e determina que senhas, quando utilizadas fora do estado inicial, sejam únicas por dispositivo ou definidas pelo usuário [6]. As recomendações da CISA enfatizam a eliminação de senhas padrão e a adoção de padrões seguros desde a fabricação [7].

O escopo técnico limita-se ao comprometimento por credenciais e ao uso do equipamento como bot de DDoS. Vulnerabilidades de memória, ataques à cadeia de suprimentos, extração física de chaves, privacidade e segurança de protocolos sem fio são problemas relevantes, mas não constituem o foco. A demonstração é conceitual e controlada; ela não mede a capacidade de uma botnet real nem valida a segurança de um produto comercial.

3 Problema selecionado: credenciais inseguras

3.1 Origem da vulnerabilidade

Uma credencial padrão é uma combinação de identidade e segredo definida pelo fabricante para instalação, manutenção ou recuperação. Ela se torna um problema quando é igual em uma família de produtos, aparece em manuais ou fóruns, não pode ser alterada, permanece ativa após a configuração ou protege serviços acessíveis por redes não confiáveis. Uma senha individual ainda pode ser insegura quando segue um padrão previsível derivado, por exemplo, do endereço MAC ou do nome da rede [6].

O erro não pertence exclusivamente ao usuário. Se o produto funciona normalmente sem exigir a troca da senha, a configuração insegura tende a persistir. Em implantações grandes, alterar centenas de credenciais manualmente também pode levar à reutilização ou a registros desprotegidos. A abordagem de segurança por padrão transfere parte da solução para o projeto: cada unidade deve sair com segredo inicial único, ou exigir que o proprietário defina um segredo antes de habilitar a operação normal [7, 6].

Três condições transformam a fragilidade em comprometimento remoto: uma interface de administração ativa, alcance de rede até essa interface e autenticação previsível. A falha é especialmente grave quando o serviço concede privilégios administrativos e o dispositivo executa um sistema operacional capaz de baixar ou iniciar programas. Mesmo que o equipamento armazene poucos dados sensíveis, seus recursos de rede podem ser apropriados para ataques contra terceiros.

3.2 Impactos

A confidencialidade pode ser afetada pelo acesso a imagens, áudio, configuração ou topologia. A integridade pode ser violada por mudanças no DNS, nas regras de encaminhamento ou no comportamento de sensores e atuadores. A disponibilidade pode ser reduzida tanto localmente, pelo consumo de processador e banda, quanto externamente, quando milhares de dispositivos enviam tráfego coordenado a uma vítima.

O efeito distribuído altera a escala do risco. Um único dispositivo tem capacidade limitada, mas uma botnet agrega conexões de muitos provedores e localidades. Bloquear um endereço não interrompe a campanha, e distinguir tráfego malicioso de fluxos legítimos pode exigir defesa na rede da vítima ou de seu provedor. Kolias et al. observam que a disponibilidade e a diversidade de dispositivos IoT favoreceram botnets capazes de DDoS [4].

4 Ataque específico: comprometimento ao estilo Mirai

4.1 Caso histórico

O Mirai ganhou visibilidade em 2016 após ataques contra organizações como Krebs on Security, OVH e o provedor de DNS Dyn. A análise longitudinal estimou um pico de aproximadamente 600 mil dispositivos infectados [3]. Os alvos vulneráveis eram principalmente equipamentos embarcados com serviços Telnet expostos. O malware testava uma lista de 64 pares de usuário e senha, explorando a repetição de credenciais entre modelos e fabricantes.

O estudo também mostra que o ecossistema não era uma única máquina. Havia componentes para localizar dispositivos, relatar acessos válidos, carregar o código apropriado à arquitetura do equipamento, manter comando e controle e coordenar o tráfego contra alvos [3].

Essa divisão permite que a busca por novos bots continue enquanto os dispositivos já comprometidos aguardam comandos.

O comprometimento podia ser temporário porque muitos dispositivos executavam o agente apenas em memória. Reiniciar poderia removê-lo, mas não eliminava a causa. Se a senha vulnerável e o serviço exposto permanecessem, o dispositivo poderia ser infectado novamente. Portanto, reinicialização é contenção momentânea, não correção.

4.2 Encadeamento do ataque

A Figura 1 sintetiza o ataque. Primeiro, um componente de varredura procura endereços que respondem em interfaces de administração. Em seguida, são testadas credenciais padrão ou previsíveis. Um acesso bem-sucedido é comunicado à infraestrutura do atacante. O carregador identifica a arquitetura do dispositivo e entrega um agente compatível. O bot passa a contatar o comando e controle, participa da descoberta de novos alvos e, quando instruído, envia tráfego ao serviço vítima [3].

Cada etapa produz evidências. Varreduras criam muitas conexões curtas; tentativas de acesso aparecem nos registros de autenticação; a instalação pode alterar processos, memória ou arquivos temporários; o comando e controle cria conexões de saída incomuns; e o DDoS aumenta abruptamente o volume e a taxa de pacotes. A ausência de um único indicador não comprova segurança, pois dispositivos simples podem não registrar eventos e variantes podem modificar protocolos.

4.3 Por que o ataque funciona

O ataque é econômico porque explora homogeneidade. Uma lista curta de credenciais pode valer para milhares de unidades, e a tentativa pode ser automatizada. Equipamentos perma-

Tabela 1: Relação entre a falha, os ativos afetados e os impactos possíveis.

Condição	Ativo diretamente exposto	Efeito no proprietário	Efeito externo
Senha universal ou conhecida	Conta administrativa	Perda de controle e alteração da configuração	Comprometimento automatizado de muitas unidades
Serviço remoto exposto Software sem atualização segura	Interface Telnet, SSH ou Web Firmware e serviços	Tentativas de autenticação e exploração contínuas Persistência de vulnerabilidades e reinfecção	Ampliação da população alcançável pela botnet Manutenção de infraestrutura maliciosa
Rede sem segmentação Ausência de monitoramento	Outros dispositivos e sistemas Registros e fluxos de rede	Movimento lateral e maior impacto local Comprometimento permanece despercebido	Uso de conexões internas como origem de ataques Bot participa de varreduras e DDoS por mais tempo

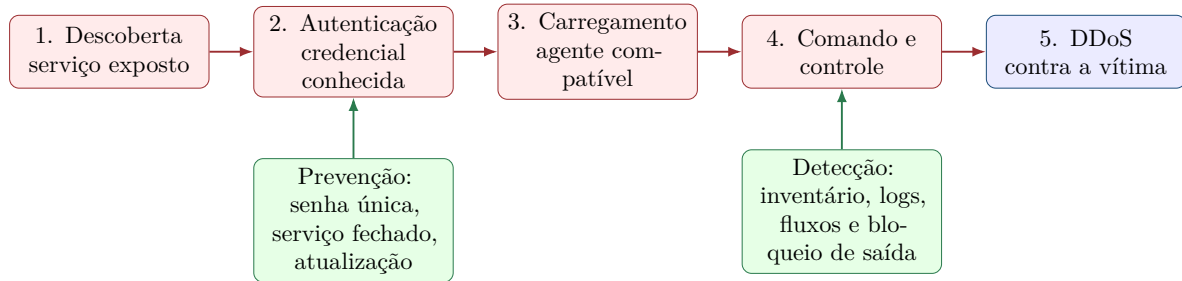


Figura 1: Encadeamento conceitual do comprometimento e pontos de interrupção. Elaborado pelos autores a partir de Antonakakis et al. [3].

necem ligados continuamente, possuem acesso à Internet e nem sempre executam proteção de endpoint. Além disso, o proprietário pode não perceber a infecção enquanto a função principal, como exibir vídeo ou encaminhar pacotes, continua disponível.

A autenticação fraca é a porta de entrada, mas o dano depende de outras fragilidades: exposição do serviço, privilégio excessivo, execução de software não autorizado, falta de atualização e comunicação de saída sem controle. Por isso, substituir a senha bloqueia o caminho descrito, mas não constitui uma estratégia completa para segurança do produto.

5 Demonstração segura em ambiente controlado

5.1 Topologia e limites

A demonstração proposta utiliza uma rede virtual sem roteamento para a Internet, formada por quatro elementos: uma estação de teste autorizada, um dispositivo IoT simulado, um controlador simulado e um servidor que representa a vítima. O dispositivo contém deliberadamente uma conta de laboratório e um serviço de administração. O firewall da máquina hospedeira bloqueia entrada e saída da rede virtual, impedindo varredura, propagação ou tráfego para endereços externos.

Não é necessário executar o código do Mirai. Um programa benigno pode representar o agente ao enviar uma mensagem periódica ao

controlador. O suposto DDoS é substituído por uma quantidade pequena e previamente limitada de requisições ao servidor local. A finalidade é observar transições de estado e registros, não medir saturação. Todos os endereços pertencem ao laboratório e o operador mantém autorização sobre cada componente.

5.2 Procedimento

O primeiro passo é registrar o estado inicial: serviço disponível, conta configurada, conexões existentes e consumo normal. A estação de teste então verifica somente o endereço do dispositivo simulado e constata a interface administrativa exposta. Uma tentativa com a credencial de laboratório demonstra que o segredo conhecido concede acesso. Não se realiza varredura de faixas públicas nem teste contra equipamento de terceiros.

Após o acesso, um marcador benigno representa o agente. Ele não possui persistência, exploração, capacidade de propagação ou comandos de sistema. O marcador contata o controlador local em intervalos definidos e recebe apenas a instrução para realizar poucas requisições HTTP ao servidor de teste. Um limite de taxa garante que o serviço não seja indisponibilizado. Essa etapa demonstra a coordenação distribuída sem reproduzir o efeito nocivo.

Por fim, aplicam-se as correções: substituição da credencial, desativação do serviço de administração desnecessário, regra de firewall e bloqueio da comunicação do marcador. A repetição do ensaio deve produzir falha de autenticação e ausência de conexão de comando e controle. Os registros antes e depois permitem associar cada medida ao ponto do ataque que ela interrompe.

5.3 Interpretação e limitações

O ensaio demonstra causalidade no cenário restrito: quando a credencial conhecida e a interface exposta coexistem, ocorre acesso; quando esses fatores são removidos, o mesmo caminho falha. Ele também permite verificar indicadores de rede e registros. Contudo, não autoriza extrapolar volume, alcance ou eficácia para a Internet. Um único dispositivo simulado não representa a diversidade de arquiteturas, firmwares e mecanismos de persistência observada em botnets reais.

Não se deve chamar o tráfego limitado de DDoS real, porque não há distribuição ampla nem indisponibilidade. Trata-se de uma simulação do fluxo de controle. A escala histórica e os impactos do Mirai provêm da literatura citada, não do ensaio proposto.

6 Medidas para sanar e reduzir o problema

6.1 Projeto e fabricação

A medida mais direta é eliminar senhas universais. A ETSI requer senhas únicas por dispositivo ou definidas pelo usuário depois do estado de fábrica e recomenda que valores pré-instalados sejam gerados de modo resistente a ataques automatizados [6]. A CISA recomenda senha inicial individual ou definição obrigatória durante a configuração, de forma que o produto não dependa de o usuário descobrir posteriormente uma opção de segurança [7].

O produto também deve reduzir interfaces e privilégios. Serviços de manutenção desnecessários precisam ser desativados; os necessários devem aceitar somente protocolos protegidos e entidades autorizadas. Segredos não devem ser recuperáveis por mecanismos triviais, e tentativas repetidas devem sofrer limitação de taxa. Para autenticação entre máquinas, cha-

Tabela 2: Plano da demonstração controlada e evidências esperadas.

Fase	Ação permitida no laboratório	Evidência coletada	Critério de segurança
Preparação	Isolar a rede e registrar os ativos próprios	Diagrama, endereços locais e regras do firewall	Nenhuma rota para Internet ou terceiros
Descoberta	Consultar apenas o dispositivo simulado	Conexão registrada na interface administrativa	Escopo limitado a um endereço autorizado
Acesso	Usar a credencial deliberadamente configurada	Sucesso no log e sessão de laboratório	Sem tentativa massiva ou quebra de senha
Controle	Executar marcador benigno sem persistência	Conexão periódica ao controlador local	Sem código Mirai ou execução arbitrária
Tráfego	Enviar poucas requisições ao servidor local	Contagem e taxa de requisições	Limite incapaz de causar indisponibilidade
Mitigação	Trocar credencial, fechar serviço e bloquear saída	Falha de acesso e ausência de comunicação	Estado restaurável e registros preservados

ves ou certificados individuais são preferíveis a senhas humanas compartilhadas.

Atualizações precisam ser autenticadas, íntegras e disponibilizadas durante um período declarado de suporte. O NIST inclui atualização segura, restrição de acesso lógico às interfaces e capacidade de informar o estado de segurança entre os elementos da linha de base [5]. Inicialização verificada e proteção da integridade dificultam a execução de agentes não autorizados, ainda que uma conta seja comprometida.

6.2 Implantação e operação

O integrador deve manter inventário de dispositivos, modelos, versões, responsáveis e datas de fim de suporte. Antes de conectar um equipamento, deve alterar credenciais, desativar contas e serviços não utilizados, aplicar atualizações e verificar se a interface administrativa está exposta. Administração remota, quando necessária, pode ser restrita a uma rede de gestão ou a uma VPN, em vez de publicada diretamente na Internet.

A segmentação limita o alcance do comprometimento. Câmeras, sensores e atuadores devem ocupar redes coerentes com suas funções, com regras explícitas para destinos e protocolos necessários. Filtrar tráfego de saída reduz a pos-

sibilidade de contato com comando e controle e dificulta que um bot envie pacotes arbitrários. A segmentação não corrige a senha, mas contém impactos e melhora a visibilidade.

Monitoramento deve combinar registros de autenticação, alterações de configuração, consultas DNS e fluxos de rede. Indicadores úteis incluem aumento de tentativas de acesso, conexões para destinos inéditos, varredura lateral, taxa anormal de pacotes e comunicação fora do perfil do dispositivo. A capacidade de relatar o estado de segurança é parte da linha de base do NIST e apoia investigação e resposta [5].

6.3 Resposta a incidentes

Ao identificar um dispositivo suspeito, a organização deve isolá-lo da rede, preservar registros relevantes e bloquear destinos associados. Reiniciar pode interromper um agente residente somente em memória, mas não deve ser considerado solução. A recuperação inclui redefinir credenciais, atualizar ou reinstalar firmware por fonte confiável, remover exposições e verificar outros exemplares do mesmo modelo.

Se o produto não recebe correções, não permite trocar credenciais ou depende de serviço inseguro, a substituição ou desativação pode ser a única medida consistente com o risco. Depois

da recuperação, convém revisar por que o ativo estava exposto e atualizar os controles de aquisição. Um incidente em um exemplar indica possível falha comum a toda a frota.

7 Discussão

O caso Mirai mostra que a segurança de IoT não pode ser avaliada apenas pela sensibilidade dos dados armazenados. Um equipamento sem informações valiosas ainda oferece processamento, banda e uma origem distribuída. O proprietário sofre consumo e perda de controle, enquanto a vítima externa recebe o impacto mais visível. Essa separação de custos ajuda a explicar por que práticas inseguras podem persistir sem exigências de aquisição e fabricação.

Também é insuficiente atribuir o problema exclusivamente à escolha de senha do usuário. Produtos com segredos universais, interfaces expostas e atualização inadequada criam condições estruturais para abuso em escala. As orientações do NIST, da ETSI e da CISA convergem na necessidade de controles incorporados ao produto e de apoio durante seu ciclo de vida [5, 6, 7].

Não existe uma única medida que elimine todas as variantes de botnet. Credenciais individuais reduzem o ataque descrito, mas vulnerabilidades de software podem fornecer outra entrada. Fechar uma interface limita a exposição, mas uma cadeia de suprimentos comprometida ou uma rede local hostil permanece possível. A resposta adequada é defesa em profundidade: prevenção na identidade e nas interfaces, contenção na arquitetura de rede, visibilidade para detecção e processo de recuperação.

Para aquisição, a organização pode transformar essas medidas em requisitos verificáveis: ausência de senha universal, prazo de suporte declarado, atualização autenticada, documentação de serviços, registro de eventos e

mecanismo de restauração. Esse procedimento é mais objetivo do que aceitar declarações genéricas de que um produto é “seguro”.

8 Conclusão

Credenciais padrão ou previsíveis constituem um problema crítico em redes IoT porque uma falha replicada em muitos equipamentos permite comprometimento automatizado. O Mirai demonstrou esse encadeamento ao localizar interfaces Telnet, testar uma lista reduzida de credenciais, incorporar dispositivos a uma botnet e coordená-los em ataques DDoS. A estimativa de pico de aproximadamente 600 mil infecções pertence à análise histórica de Antonakakis et al.; a demonstração proposta neste relatório apenas reproduz, de forma benigna e isolada, a sequência lógica do ataque [3].

Sanar o problema exige eliminar credenciais universais, obrigar configuração segura, restringir interfaces, fornecer atualizações autenticadas e impedir execução não autorizada. Na implantação, inventário, segmentação, controle de exposição e filtragem de saída reduzem alcance e impacto. Monitoramento e resposta completam o ciclo, pois permitem identificar comportamento anormal, isolar o equipamento e corrigir a causa antes da reconexão.

O principal aprendizado é que trocar uma senha é necessária, mas não suficiente. A segurança depende de decisões coordenadas de fabricante, integrador e operador, desde o projeto até o fim do suporte. A combinação dessas responsabilidades reduz tanto o risco local quanto a possibilidade de dispositivos legítimos se tornarem infraestrutura para ataques contra terceiros.

Referências

- [1] OWASP Foundation, “OWASP Internet of Things Top 10,” 2018, acesso em: 26 set. 2026. [Online].

Tabela 3: Defesa em profundidade para o cenário estudado.

Responsável	Medida	Etapas interrompida	Verificação
Fabricante	Credencial única ou criação obrigatória no primeiro uso	Autenticação automatizada	Duas unidades não compartilham segredo; produto não opera com senha universal
Fabricante	Desativar serviços desnecessários e fornecer atualização autenticada	Descoberta e instalação do agente	Teste de portas e validação criptográfica da atualização
Integrador	Remover exposição direta e usar rede de administração	Descoberta remota	Interface inacessível a partir de redes não autorizadas
Operador	Inventariar, atualizar e substituir itens sem suporte	Exploração e permanência	Versão e prazo de suporte registrados por ativo
Rede	Segmentar e permitir somente comunicações necessárias	Comando, propagação e DDoS	Teste de regras para origem, destino, porta e direção
Monitoramento	Alertar sobre autenticação, varredura e tráfego anormal	Permanência e ação sobre objetivos	Logs centralizados e alerta exercitado
Resposta	Isolar, restaurar e corrigir a causa	Continuidade do comprometimento	Repetição do teste falha após a correção

Available: <https://owasp.org/projects/internet-of-things/>

- [2] Cybersecurity and Infrastructure Security Agency and National Security Agency, “Nsa and cisa red and blue teams share top ten cybersecurity misconfigurations,” CISA, Tech. Rep. AA23-278A, 2023. [Online]. Available: <https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-278a>
- [3] M. Antonakakis, T. April, M. Bailey, M. Bernhard, E. Bursztein, J. Cochran, Z. Durumeric, J. A. Halderman, L. Invernizzi, M. Kallitsis, D. Kumar, C. Lever, Z. Ma, J. Mason, D. Menscher, C. Seaman, N. Sullivan, K. Thomas, and Y. Zhou, “Understanding the Mirai botnet,” in *26th USENIX Security Symposium (USENIX Security 17)*. Vancouver, Canada: USENIX Association, 2017, pp. 1093–1110. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity17/technical-sessions/presentation/antonakakis>
- [4] C. Koliass, G. Kambourakis, A. Stavrou, and J. Voas, “DDoS in the IoT: Mirai and other botnets,” *Computer*, vol. 50, no. 7, pp. 80–84, 2017. [Online]. Available: <https://doi.org/10.1109/MC.2017.201>
- [5] M. Fagan, K. Megaw, K. Scarfone, and M. Smith, “IoT device cybersecurity capability core baseline,” National Institute of Standards and Technology, Tech. Rep. NISTIR 8259A, 2020. [Online]. Available: <https://doi.org/10.6028/NIST.IR.8259A>
- [6] European Telecommunications Standards Institute, “Cyber security for consumer internet of things: Baseline requirements,” ETSI, Tech. Rep. ETSI EN 303 645 V3.1.3, 2024. [Online]. Available: https://www.etsi.org/deliver/etsi_en/303600_303699/303645/03.01.03_60/en_303645v030103p.pdf

- [7] Cybersecurity and Infrastructure Security Agency, “How software manufacturers can protect customers by eliminating default passwords,” CISA, Tech. Rep., 2023. [Online]. Available: https://www.cisa.gov/sites/default/files/2023-12/SbD-Alert-How-Software-Manufacturers-Can-Protect-Customers-by-Eliminating-Default-Passwords-508c_0.pdf